

W03 · M03 · 20 MINIT / MINUTES · Hari 1, 15:05 hingga 15:25

Hands-On SQA-AI Assistant Workshop

AI design review and 5 x 5 risk register

Semakan reka bentuk AI dan daftar risiko 5 x 5

Review the ShopFast architecture and OpenAPI contract with the AI, challenge one finding for evidence, then build a scored risk register in PPrISA07 format.

opencode 1.18 · model Big Pickle (OpenCode Zen, free, no API key) · synthetic ShopFast data only

Bengkel SQA KRISAv2 dan PPrISA 2.0 · 14 hingga 15 September 2026 · Makmal Komputer Aras 11, Menara MyIPO

[Web guide \(copy prompts\)](#)

[Module hub](#)

[Example outputs \(GitHub\)](#)

Before you start / Sebelum mula

YOU WILL / ANDA AKAN

1. Run /design-review on the order endpoint
2. Challenge one finding: ask for the exact line as evidence
3. Run /risk-register and approve the CSV
4. Sort by score and agree the top three test priorities

1. Jalankan /design-review untuk endpoint pesanan
2. Cabar satu penemuan: minta baris tepat sebagai bukti
3. Jalankan /risk-register dan luluskan CSV
4. Susun mengikut skor dan setuju tiga keutamaan ujian teratas

CHECK FIRST / SEMAK DAHULU

- PowerShell is in C:\Users\<you>\sqa-krisa-bengkel\lab
- opencode starts and shows Big Pickle, OpenCode Zen (W00)

Data rules / Peraturan data

- Synthetic ShopFast data only. Never paste real agency documents or personal data.
- Free models run outside Malaysia and may learn from prompts.
- AI output is a draft. A person checks and signs off.

OUTPUT

outputs/m03-risk-register.csv

W03 · STEP 1 OF 5 · LANGKAH 1

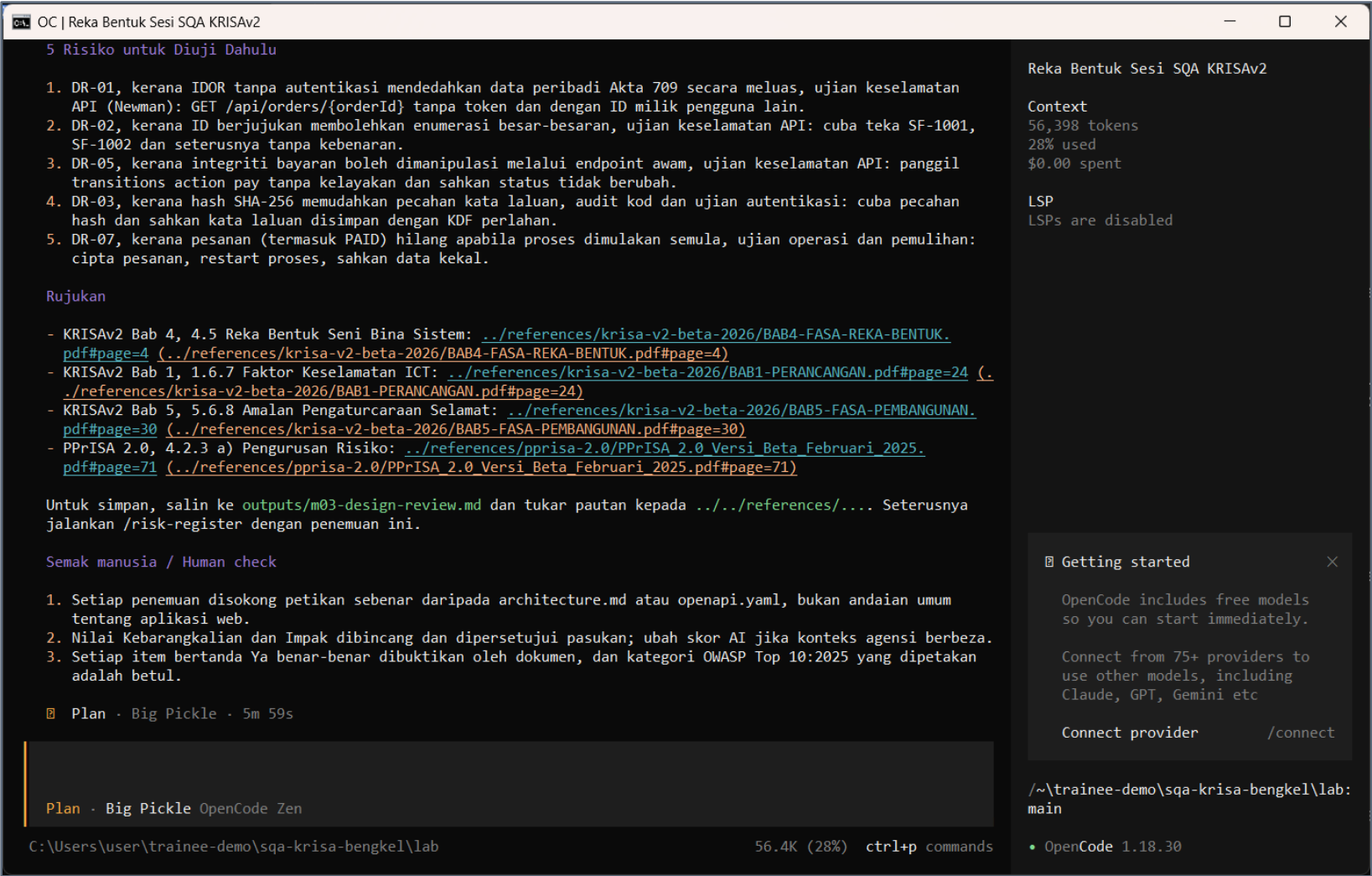
Run the design review in Plan mode for the order endpoint.

Jalankan semakan reka bentuk dalam mod Plan untuk endpoint pesanan.

TYPE IN OPENCODE (PLAN)

Salin / Copy

```
/design-review GET /api/orders/{orderId}
```



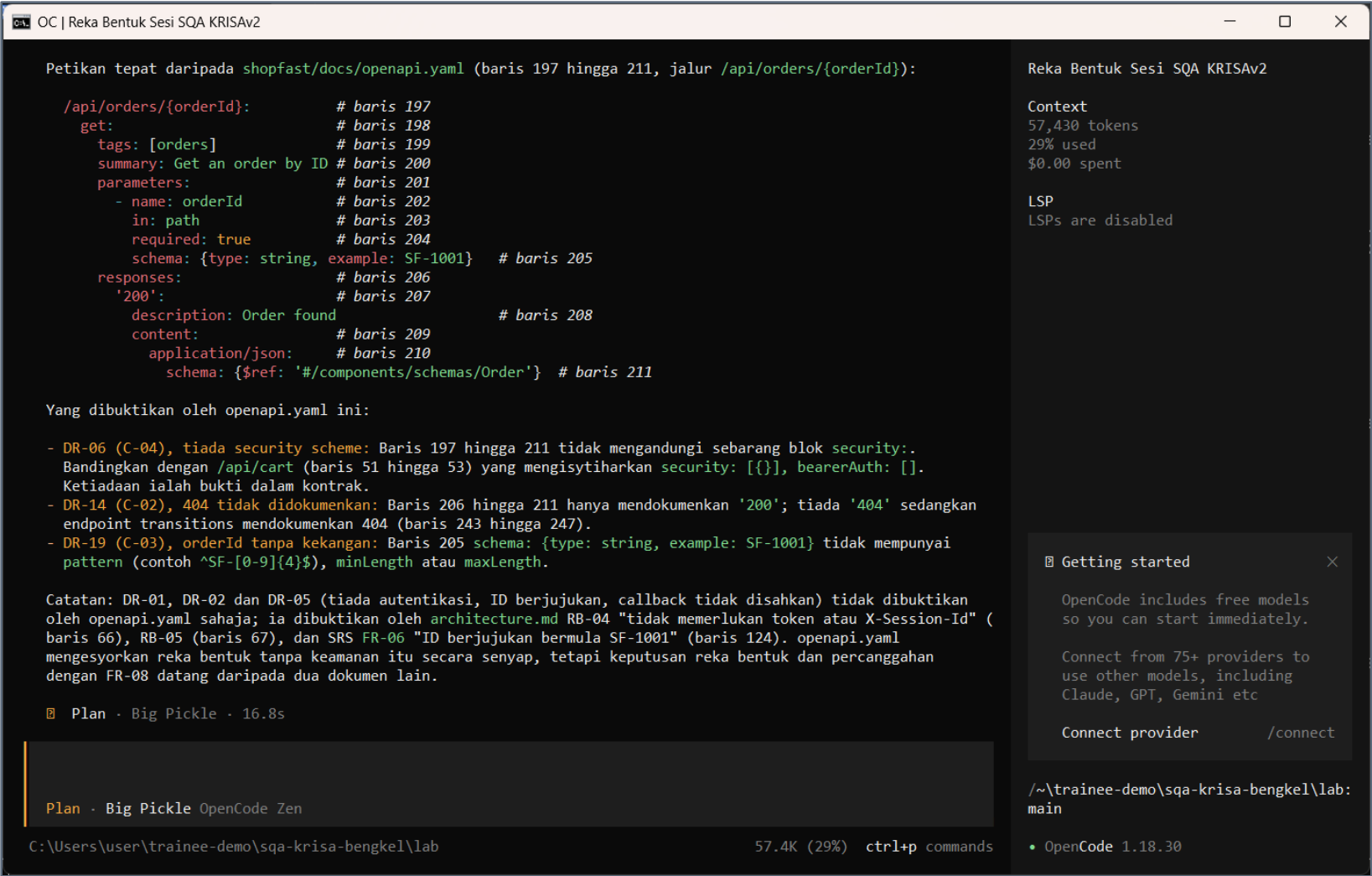
Challenge the AI: ask for the exact line that proves the finding.

Cabar AI: minta baris tepat yang membuktikan penemuan.

TYPE IN OPENCODE (PLAN)

Salin / Copy

Petik baris tepat dalam shopfast/docs/openapi.yaml yang membuktikan penemuan anda tentang GET /api/orders/{orderId}.



W03 · STEP 3 OF 5 · LANGKAH 3

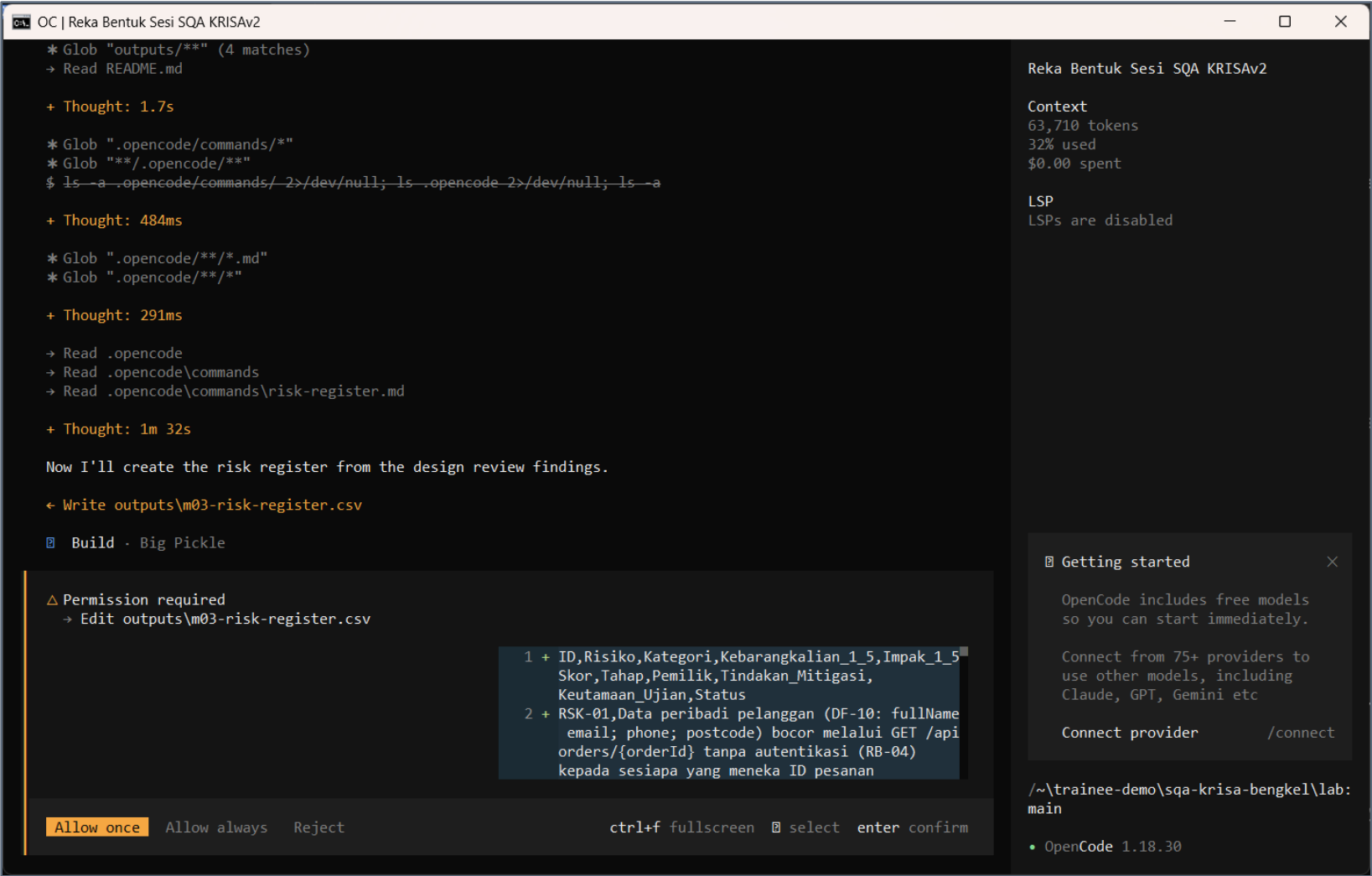
Switch to Build and run /risk-register. Review the permission. The AI reads the documents first and may pause at Preparing write. When the Permission required dialog appears, read the preview and choose Allow once.

Tukar ke Build dan jalankan /risk-register. Semak kebenaran. AI membaca dokumen dahulu dan mungkin berhenti seketika pada Preparing write. Apabila dialog Permission required muncul, baca pratonton dan pilih Allow once.

TYPE IN OPENCODE (BUILD)

Salin / Copy

/risk-register checkout ShopFast berdasarkan penemuan semakan reka bentuk di atas



Allow once. The risk register CSV is saved.

Allow once. CSV daftar risiko disimpan.

TYPE IN OPENCODE

Salin / Copy

Allow once (Enter)

OC | Reka Bentuk Sesi SQA KRISAv2

5 Risiko Teratas

ID	Risiko	Skor	Tahap	Keutamaan_Ujian
RSK-01	Data peribadi bocor melalui GET /api/orders/{orderId} tanpa autentikasi (RB-04) bercanggah FR-08	25	Kritikal	P1
RSK-02	ID pesanan berjujukan SF-1001 boleh ditekakan tanpa kawalan akses (FR-06)	20	Kritikal	P1
RSK-03	Kata laluan di-hash dengan SHA-256 (RB-02) bukan Argon2id/bcrypt	16	Tinggi	P1
RSK-04	Tiada rate limiting (RB-03); password spraying tidak dikawal	16	Tinggi	P1
RSK-05	Callback FPX (DF-07) tiada tandatangan; status pesanan boleh dimanipulasi (RB-05)	16	Tinggi	P1

Rujukan

- [PPrISA07 Pelan Pengurusan Risiko](#) (../references/pprisa-2.0/templates/pdf/PPrISA07-Pelan_Pengurusan_Risiko.pdf)
- [PPrISA 2.0, 4.2.3 a\) Pengurusan Risiko](#) (../references/pprisa-2.0/PPrISA_2.0_Versi_Beta_Februari_2025.pdf#page=71)

Semak manusia / Human check

1. Sahkan bagi setiap baris bahawa Skor = Kebarangkalian x Impak dan Tahap serta Keutamaan_Ujian mengikut skala templat.
2. Setiap risiko boleh dijejak ke dokumen sumber (RB, DF, REQ-CHK atau FR) dan bukan risiko generik yang disalin dari internet.
3. Pemilik dan tindakan mitigasi realistik untuk agensi anda, dan tindakan ujian boleh dimasukkan ke dalam pelan ujian.

Build · Big Pickle · 3m 28s

Build · Big Pickle OpenCode Zen

C:\Users\user\trainee-demo\sqa-krisa-bengkel\lab72.5K (36%)ctrl+p commands

Reka Bentuk Sesi SQA KRISAv2

Context

72,486 tokens
36% used
\$0.00 spent

LSP

LSPs are disabled

Getting started

OpenCode includes free models so you can start immediately.

Connect from 75+ providers to use other models, including Claude, GPT, Gemini etc

Connect provider /connect

/~\trainee-demo\sqa-krisa-bengkel\lab: main

• OpenCode 1.18.30

Sort by score and agree the top three test priorities.

Susun mengikut skor dan setuju tiga keutamaan ujian teratas.

TYPE IN POWERSHELL

[Salin / Copy](#)

```
Import-Csv outputs\m03-risk-register.csv |
Sort-Object {[int]$_Skor} -Descending |
Format-Table -AutoSize -Wrap
```

```
SQA-SHOT-ef8403
PS C:\Users\user\trainee-demo\sqa-krisa-bengkel\lab> Import-Csv outputs\m03-risk-register.csv | Sort-Object {[int]$_Skor} -Descending | Select-Object ID,Risiko,Kebarangkalian_1_5,Impak_1_5,Skor,Keutamaan_Ujian -First 10 | Format-Table -AutoSize -Wrap

ID      Risiko
--      -
RSK-01  Data peribadi pelanggan (DF-10: fullName; email; phone; postcode) bocor melalui GET /api/orders/{orderId} tanpa autentikasi (RB-04) kepada sesiapa yang meneka ID pesanan berjujukan (FR-06: SF-1001); bercanggah dengan FR-08 yang menetapkan hanya pengguna berdaftar boleh melihat pesanan
RSK-02  ID pesanan berjujukan SF-1001 (FR-06) membolehkan penyerang meneka dan mengakses pesanan pengguna lain tanpa kebenaran; kombinasi ID boleh diteka dengan tiada kawalan akses memudahkan eksploitasi
RSK-05  Callback FPX (DF-07) dihantar melalui endpoint peralihan yang hanya memerlukan X-Session-Id sebarang rentetan (RB-05) tanpa tandatangan atau pengesahan asal; penyerang boleh menanda pesanan PAID atau FAIL tanpa bayaran sebenar
RSK-04  Tiada had kadar permintaan (rate limiting) pada lapisan API (RB-03); penguncian akaun 3 cubaan hanya melindungi satu akaun; password spraying merentas banyak akaun tidak dikawal
RSK-03  Kata laluan disimpan dengan SHA-256 + salt (RB-02) yang merupakan hash pantas; bukan bcrypt atau Argon2id; kata laluan lemah boleh dipecah secara offline menggunakan BTC
RSK-06  Data pesanan hilang apabila proses dimulakan semula kerana stor dalam memori sahaja (architecture.md baris 22); tiada lapisan kegigihan data; pesanan PAID dan data peribadi Akta 709 hilang
RSK-11  Masa respons checkout pada p95 hendaklah kurang daripada 2 saat dengan 50 pengguna serentak (REQ-CHK-06) belum diuji; tiada bukti ujian beban dalam CI atau persekitaran staging sebelum gate G3
RSK-10  Kontrak GET /api/orders/{orderId} hanya mendokumenkan respons 200 (openapi baris 206 hingga 211); kod 404 bagi order tidak wujud tidak dinyatakan walaupun skema Error wujud dan endpoint transitions mendokumenkan 404
RSK-07  CORS membenarkan semua origin (TB1 kepada TB2) dan GET /api/orders/{orderId} tiada pengisytiharan security scheme (openapi baris 197 hingga 211); gabungan ini membolehkan permintaan merentas domain tanpa sekatan
RSK-08  Log stdout merekod email dan phone bagi checkout (RB-06) dan peristiwa keselamatan (log masuk gagal; penguncian; peralihan tidak sah) tidak direkodkan dengan identiti pelaku; tiada mekanisme amaran (alerting); data peribadi bocor ke log

PS C:\Users\user\trainee-demo\sqa-krisa-bengkel\lab>
```

Human check before you accept the output / Semakan manusia

Findings quote the exact path or line in openapi.yaml or architecture.md

Penemuan memetik laluan atau baris tepat dalam openapi.yaml atau architecture.md

Scores use 1 to 5 scales and Skor = K x I

Skor menggunakan skala 1 hingga 5 dan Skor = K x I

Each top risk has a test priority, not only a mitigation

Setiap risiko utama mempunyai keutamaan ujian, bukan sekadar mitigasi

The AI draft becomes evidence only after this check. Record who checked it and when (Module 7 audit trail).

If something goes wrong / Jika ada masalah

opencode is not recognised

Close and reopen PowerShell so PATH refreshes. Still failing: `powershell -ExecutionPolicy Bypass -File .\setup\install-opencode.ps1 -Portable`

Scripts are disabled on this system

`Set-ExecutionPolicy -Scope CurrentUser RemoteSigned`, or run `opencode.cmd` instead of `opencode`

The model is slow or stops

Wait up to 2 minutes. Press Esc to interrupt, then send the prompt again. Try another free model with `/models`

Permission required dialog

Read the preview. Choose Allow once for files in `outputs/`. Reject anything outside the lab folder

File or command not found

Check the status bar path ends with `\lab`. Commands and `@files` are relative to the lab folder

Answer uses Indonesian words or dashes

Reply: Ikut AGENTS.md peraturan 1 dan 14, tulis semula dalam Bahasa Melayu Malaysia

Network or proxy error

`$env:HTTPS_PROXY = "http://proxy:port"` and `$env:NO_PROXY = "localhost,127.0.0.1"` before starting opencode

Port 3000 already in use

`$env:PORT = 3001` before npm start, and use `http://localhost:3001`

Abbreviations / Singkatan (1 of 2)

Short forms used in this workshop, in plain words. / Singkatan dalam bengkel ini, dengan bahasa mudah.

Abbreviation / Singkatan	Stands for / Maksud penuh	In plain words / Maksud mudah
AI	Artificial Intelligence	Software that can answer questions and write text or code by learning patterns from large amounts of data. <i>Kecerdasan Buatan. Perisian yang boleh menjawab soalan dan menulis teks atau kod berdasarkan pola daripada data yang banyak.</i>
API	Application Programming Interface	A doorway that lets one program ask another program for data or an action, without using a screen. <i>Pintu yang membolehkan satu program meminta data atau tindakan daripada program lain tanpa melalui skrin.</i>
CI	Continuous Integration, or Configuration Item	Two meanings. In DevOps, every code change is built and tested automatically. In configuration management, it is any controlled item such as a document or code file. <i>Dua maksud. Dalam DevOps, setiap perubahan kod dibina dan diuji secara automatik. Dalam pengurusan konfigurasi, ia ialah item terkawal seperti dokumen atau fail kod.</i>
CI/CD	Continuous Integration and Continuous Delivery	An automated pipeline that builds, tests and prepares every change for release. <i>Saluran automatik yang membina, menguji dan menyediakan setiap perubahan untuk dikeluarkan.</i>
CSV	Comma-Separated Values	A simple table file that opens in Excel, with commas between the columns. <i>Fail jadual ringkas yang boleh dibuka dalam Excel, dengan koma di antara lajur.</i>

Abbreviations / Singkatan (2 of 2)

Short forms used in this workshop, in plain words. / Singkatan dalam bengkel ini, dengan bahasa mudah.

Abbreviation / Singkatan	Stands for / Maksud penuh	In plain words / Maksud mudah
KRISA	Kejuruteraan Sistem Aplikasi Sektor Awam	The Malaysian public sector guide for engineering application systems. KRISAv2 is the 2026 beta edition. <i>Buku Panduan Kejuruteraan Sistem Aplikasi Sektor Awam. KRISAv2 ialah edisi beta 2026.</i>
MyIPO	Perbadanan Harta Intelek Malaysia	Intellectual Property Corporation of Malaysia, the host of this training venue. <i>Perbadanan Harta Intelek Malaysia, tuan rumah lokasi latihan ini.</i>
PPriSA	Panduan Pengurusan Projek ICT Sektor Awam	The Malaysian public sector guide for managing ICT projects. Codes such as PPrISA05 are its templates. <i>Panduan Pengurusan Projek ICT Sektor Awam. Kod seperti PPrISA05 ialah templatnya.</i>
SQA	Software Quality Assurance	All the planned work that gives confidence the software meets its quality requirements. <i>Jaminan Kualiti Perisian, iaitu semua kerja terancang yang memberi keyakinan bahawa perisian memenuhi keperluan kualiti.</i>
TUI	Text User Interface	A full-screen program that runs inside a terminal window, like opencode. <i>Antara muka pengguna berasaskan teks, iaitu program skrin penuh dalam tetingkap terminal seperti opencode.</i>

Links / Pautan

[Web guide with copyable prompts](#)

[Module hub \(slides, references, templates\)](#)

[Example outputs from the real run](#)

[Lab README and command list](#)

[AGENTS.md rules used by the assistant](#)

[opencode documentation](#)

[opencode TUI commands and keys](#)

[OpenCode Zen free models and data policy](#)

[Bab 4, 4.5 Reka Bentuk Seni Bina \(p.4\)](#)

[Bab 4, Jadual 4.4 Jenis seni bina \(DevOps, CI/CD\) \(p.10\)](#)

[Bab 4, 4.12 Spesifikasi Integrasi \(p.111\)](#)